

Infraestructura y Seguridad en la Nube

La adopción de servicios en la nube ha transformado radicalmente la forma en que las organizaciones diseñan, despliegan y protegen sus entornos digitales. Este tema aborda los dos pilares esenciales para garantizar un uso eficiente y confiable de la nube: la **infraestructura técnica subyacente** y los **mecanismos de seguridad y cumplimiento** que protegen la información y los servicios.

Ejemplo: Una empresa del sector sanitario que gestiona historiales clínicos ha migrado su infraestructura a la nube para garantizar alta disponibilidad y acceso remoto. Para cumplir con normativas como el **RGPD** y la **Ley de Protección de Datos en salud**, ha desplegado su backend en una región europea, configurado roles con mínimos privilegios y cifrado de datos en reposo. Además, ha habilitado monitorización de accesos para proteger la confidencialidad de la información médica.

En primer lugar, se estudia cómo está organizada la **infraestructura global de la nube**, es decir, los centros de datos distribuidos por regiones, zonas de disponibilidad y zonas de borde. Este apartado permite entender cómo se logra la alta disponibilidad, la baja latencia y el cumplimiento normativo en distintos países.

Luego, se analizan las **categorías de servicios ofrecidos en la nube**, incluyendo recursos de cómputo, almacenamiento, bases de datos, redes, monitorización y gestión. Estos elementos forman la base de cualquier arquitectura cloud moderna.

En la segunda parte, el enfoque se centra en la **seguridad en la nube**, abordando el modelo de **responsabilidad compartida**, que define claramente qué protege el proveedor y qué debe proteger el cliente. También se abordan temas clave como el **control de autenticación, autorización y federación**, la **seguridad de cuentas y datos**, y el cumplimiento de **normativas internacionales y sectoriales** (como el RGPD, HIPAA o ISO 27001).

Este bloque de contenidos es esencial para comprender cómo proteger entornos cloud frente a accesos no autorizados, pérdida de datos, errores de configuración o incumplimientos legales.



Elaboración propia. *Infraestructura* (CC BY-NC-SA)

? Preguntas Introductorias

1. ¿Qué diferencias existen entre región, zona de disponibilidad y zona de borde en una infraestructura cloud?
2. ¿Qué ventajas ofrece una infraestructura global distribuida?

3. **¿Qué tipos de servicios se incluyen en las principales categorías de la nube (cómputo, almacenamiento, redes, etc.)?**
4. **¿En qué consiste el modelo de responsabilidad compartida?**
5. **¿Qué elementos están bajo la responsabilidad del proveedor y cuáles del cliente?**



**Comunidad
de Madrid**



EducaMadrid
Plataforma Educativa

CM. Logotipo de Comunidad Madrid ([CC BY-NC-SA](#))

1. Seguridad en la nube.

La **seguridad en la nube** es uno de los aspectos más críticos en cualquier entorno digital moderno. A medida que las organizaciones trasladan cargas de trabajo y datos sensibles a plataformas cloud, deben adaptar sus políticas, herramientas y responsabilidades para mantener la **confidencialidad, integridad y disponibilidad** de la información.

A diferencia de los centros de datos tradicionales, en la nube la seguridad se **comparte entre el proveedor y el cliente**. Esto exige una comprensión clara de los límites de responsabilidad y la aplicación rigurosa de buenas prácticas en gestión de usuarios, cifrado, control de acceso, auditoría,  cumplimiento normativo y respuesta ante incidentes.

El objetivo de este bloque es capacitar al usuario para identificar riesgos y aplicar medidas técnicas y organizativas que garanticen un uso seguro de la nube, tanto desde el punto de vista **técnico** como **legal y normativo**.

Componentes esenciales para proteger un entorno cloud

La seguridad en la nube no se limita a un único sistema o herramienta: es un conjunto de **principios, controles y responsabilidades interconectadas**. Cada uno de estos elementos cumple una función específica en la protección de datos, identidades y recursos en la nube.



Elaboración propia. SLA ([CC BY-NC-SA](#))

A continuación, se presentan los **pilares fundamentales** que toda organización debe conocer y aplicar para construir un entorno cloud seguro, trazable y conforme a la normativa vigente. Cada apartado incluye un enfoque técnico acompañado de ejemplos reales para facilitar su comprensión y aplicación práctica.



Modelo de responsabilidad compartida

Define claramente **qué gestiona el proveedor** (como la infraestructura, red, centros de datos) y **qué gestiona el cliente** (configuración, seguridad de datos, identidades, aplicaciones).

➡ **Ejemplo:** Si se produce una brecha por una mala configuración de permisos en un bucket, la responsabilidad es del cliente.



Control de autenticación, autorización y federación

Se abordan los mecanismos que aseguran que **solo personas o sistemas autorizados accedan a los recursos**.

Incluye contraseñas robustas, 🔑 autenticación multifactor (MFA), uso de grupos, políticas y conexión con sistemas de identidad externos (federación).

➡ **Ejemplo:** Integrar Google Workspace o Azure AD para que los usuarios accedan con una sola cuenta a múltiples servicios cloud.



Seguridad en las cuentas

Analiza cómo proteger **identidades individuales, credenciales, claves y accesos privilegiados**.

Requiere aplicar el principio de **mínimo privilegio**, rotación de credenciales, bloqueo tras intentos fallidos, y auditoría de accesos.

➡ **Ejemplo:** En AWS, crear una 🔑 cuenta IAM por usuario y evitar el uso de la 🔑 cuenta root.



Seguridad en los datos

Incluye **cifrado en tránsito y en reposo**, gestión de claves de cifrado (KMS), replicación geográfica segura, y políticas de retención y backup. Protege contra pérdidas, robos, accesos no autorizados y corrupción de datos.

➡ **Ejemplo:** Cifrar archivos almacenados en Google Cloud Storage con claves gestionadas por el cliente (CMEK).



Seguridad en el cumplimiento normativo

Trata el alineamiento con leyes y certificaciones, como 📌 **RGPD, HIPAA, ISO 27001, SOC 2, PCI DSS.**

Implica ubicación geográfica de los datos, trazabilidad, auditorías y políticas de retención adecuadas.

➡ **Ejemplo:** Almacenar datos de pacientes únicamente en regiones europeas para cumplir el RGPD y la Ley de Protección de Datos en Sanidad.

La seguridad en la nube está compuesta por distintos principios y mecanismos que, correctamente aplicados, permiten proteger tanto los datos como los accesos a los servicios. La siguiente tabla recoge los **conceptos más relevantes** que toda organización o profesional debe dominar, junto con una **definición precisa** y un **ejemplo práctico** de aplicación en entornos reales.

Esta visión general permite entender cómo se interrelacionan la configuración, el cifrado, los accesos y el cumplimiento normativo dentro de un ecosistema cloud seguro.

Conceptos clave en seguridad en la nube

Concepto	Definición	Ejemplo práctico
Responsabilidad compartida	Modelo donde proveedor y cliente se reparten la gestión de la seguridad	El proveedor asegura la red; el cliente configura correctamente IAM y permisos
Autenticación multifactor (MFA)	Sistema que requiere más de una credencial para verificar identidad	Usuario accede con contraseña + código SMS o app de autenticación
Principio de mínimo privilegio	Dar a cada usuario solo los permisos estrictamente necesarios	Un técnico de soporte solo puede ver logs, no modificar instancias
Federación de identidades	Reutilizar credenciales externas para acceder a sistemas cloud	Acceder a AWS con credenciales de Google o Microsoft sin duplicar cuentas
Cifrado en tránsito	Protección de datos mientras viajan por la red	Uso de HTTPS, TLS o VPN entre servicios
Cifrado en reposo	Protección de datos almacenados físicamente	Archivos cifrados en S3, EBS, Blob Storage
Gestión de claves (KMS)	Servicio que crea, almacena y rota claves de cifrado automáticamente	Usar AWS KMS para cifrar volúmenes y backups
Auditoría de accesos	Registro detallado de quién accede a qué y cuándo	Revisar CloudTrail en AWS para ver quién borró una instancia
RGPD / ISO 27001	Normativas que exigen medidas específicas de protección y trazabilidad	Configurar retención de logs y localización de datos en Europa

Concepto	Definición	Ejemplo práctico
Cuenta root / administrador	Cuenta principal con todos los privilegios del entorno	Dejarla deshabilitada o con MFA activado para evitar uso indebido



Para saber más

Los siguientes enlaces se encuentran más información:

- ✓ **Guías oficiales de los proveedores cloud:** Todos los grandes proveedores ofrecen documentación detallada sobre sus herramientas de seguridad:
 - ➔ [AWS Security Documentation](#)
 - ➔ [Azure Security Center](#)
 - ➔ [Google Cloud Security Overview](#)
- ✓ **Certificaciones clave relacionadas con seguridad cloud:**
 - ➔ CCSP (Certified Cloud Security Professional)
 - ➔ AWS Certified Security – Specialty
 - ➔ Microsoft SC-900: Security, Compliance, and Identity Fundamentals
 - ➔ ISO/IEC 27001 y 27017
- ✓ **Normativas y estándares de referencia:**
 - ➔ RGPD (Reglamento General de Protección de Datos - UE)
 - ➔ HIPAA (seguridad en datos de salud - EE. UU.)
 - ➔ PCI-DSS (datos de tarjetas de pago)
 - ➔ NIST SP 800-53 (controles de seguridad en sistemas)
- ✓ **Recursos prácticos y laboratorios interactivos:**
 - ➔ [AWS Well-Architected Labs – Security Pillar](#)
 - ➔ [Google Cloud Skills Boost – Security Paths](#)
 - ➔ [Microsoft Learn – Seguridad en la nube](#)



Ejercicio Resuelto

Sara es la responsable de seguridad de una startup tecnológica que ha migrado completamente su entorno a la nube. La empresa almacena información sensible de clientes europeos y latinoamericanos, y utiliza varios servicios de almacenamiento, bases de datos y machine learning en la nube.

Durante una revisión de seguridad, Sara detecta cinco riesgos clave:

- ✓ Todos los usuarios utilizan la cuenta root compartida.
- ✓ Los datos almacenados no están cifrados.
- ✓ No hay registros de accesos ni trazabilidad.
- ✓ Un becario tiene los mismos permisos que el equipo senior.
- ✓ Los datos de usuarios europeos están siendo procesados fuera de la UE.

Su objetivo es corregir estos errores lo antes posible, aplicando buenas prácticas en seguridad cloud.

¿Qué debe hacer Sara respecto al uso compartido de la cuenta root?

Mostrar retroalimentación

Sara debe eliminar el uso compartido de la cuenta root y crear cuentas **IAM** individuales para cada usuario. La cuenta root debe estar protegida con autenticación multifactor (**MFA**), usarse solo para tareas críticas y quedar deshabilitada para el trabajo diario. Esto garantiza trazabilidad por usuario y evita accesos no controlados.

1.1 Modelo de responsabilidad compartida.

En la nube, la seguridad no es solo responsabilidad del proveedor. El modelo de **responsabilidad compartida** establece quién es responsable de cada parte del sistema: el proveedor protege la infraestructura; el cliente debe configurar y proteger correctamente sus recursos, datos y accesos.

¿Qué cubre el proveedor cloud y qué debe gestionar el cliente?

Cuando se usa un entorno en la nube, muchas personas piensan que la seguridad está totalmente garantizada por el proveedor (como AWS, Azure o Google Cloud). Sin embargo, esto **no es del todo cierto**.

La seguridad en la nube se basa en un **modelo de responsabilidad compartida**, que define claramente qué parte gestiona el **proveedor** y cuál corresponde al **cliente**.



Elaboración propia. Modelos (CC BY-NC-SA)

Este modelo **varía ligeramente según el tipo de servicio utilizado**:

Infraestructura como Servicio (IaaS)

Ejemplos: AWS EC2, Azure Virtual Machines, Google Compute Engine

Este modelo ofrece al cliente acceso directo a recursos virtuales como servidores, redes, discos duros o balanceadores de carga. Es el modelo más flexible, pero también **el que más responsabilidades de seguridad asigna al cliente**.

El proveedor es responsable de:

- ✓ La **infraestructura física**: centros de datos, energía, climatización, cableado.
- ✓ La **seguridad de la red física** y de los dispositivos.

- ✓ La **virtualización de los recursos**: el hipervisor que permite ejecutar varias máquinas virtuales sobre un mismo hardware.
- ✓ Mantenimiento de hardware, reemplazo y disponibilidad global.

El cliente es responsable de:

- ✓ El **sistema operativo** de la máquina virtual (instalación, parches, configuraciones de seguridad).
- ✓ La **configuración de red**: puertos, cortafuegos, VPN, balanceo de carga.
- ✓ La **gestión de identidades y accesos (IAM)** a las instancias.
- ✓ Las **aplicaciones** desplegadas y su código.
- ✓ El **cifrado y protección de datos en reposo y en tránsito**.
- ✓ Configuración de backups y snapshots.

✓ Ejemplo práctico:

Una empresa lanza 3 instancias EC2 en AWS para alojar su backend. El proveedor asegura que los servidores estén disponibles y operativos, pero la empresa debe actualizar el sistema operativo, configurar los firewalls y asegurar los datos almacenados.

Plataforma como Servicio (PaaS)

Ejemplos: Heroku, Google App Engine, Azure App Services

Este modelo permite centrarse en el desarrollo de aplicaciones sin preocuparse por el sistema operativo o la infraestructura. Es ideal para entornos de desarrollo y despliegue rápido, aunque el cliente aún conserva responsabilidad sobre sus datos y el uso que hace del servicio.

El proveedor es responsable de:

- ✓ Toda la **infraestructura física y virtual**.
- ✓ El **sistema operativo** que corre por debajo.
- ✓ La **gestión del entorno de ejecución** (Java, Python, Node.js, etc.).
- ✓ Parches de seguridad, actualizaciones automáticas y escalado de recursos.

El cliente es responsable de:

- ✓ El **código y las aplicaciones** que sube a la plataforma.
- ✓ La **seguridad de los datos y su tratamiento**.
- ✓ El **control de accesos y roles de usuario** a la plataforma.
- ✓ El cumplimiento normativo en cuanto a privacidad y residencia de datos.

✓ Ejemplo práctico:

Una empresa de e-learning despliega su aplicación web en Google App Engine. El proveedor se encarga del sistema operativo y los parches, pero el equipo de desarrollo debe configurar el acceso a usuarios, el tratamiento de datos personales y la seguridad del código.

Software como Servicio (SaaS)

Ejemplos: Microsoft 365, Google Workspace, Salesforce, Dropbox

En este modelo, todo el servicio es gestionado por el proveedor: el cliente accede a una aplicación a través de internet y **solo debe preocuparse por su uso correcto**. Es el

modelo más cómodo, pero el cliente aún tiene responsabilidades sobre el uso seguro de la plataforma.



El proveedor es responsable de:

- ✓ Toda la **infraestructura y plataforma** (servidores, red, sistema operativo, parches).
- ✓ El **desarrollo y mantenimiento de la aplicación**.
- ✓ **Alta disponibilidad, copias de seguridad, escalabilidad automática**.
- ✓ Seguridad general de la plataforma (cifrado, recuperación ante desastres, integridad del sistema).



El cliente es responsable de:

- ✓ La **configuración de la cuenta de usuario** (roles, contraseñas, MFA).
- ✓ La **gestión de datos y documentos subidos o generados** en el sistema.
- ✓ Definir políticas internas de acceso, retención y uso de la información.
- ✓ Cumplir la legislación sobre datos personales y confidenciales.



Ejemplo práctico:

Una clínica utiliza Google Workspace para gestionar la comunicación y almacenar historiales médicos. Google protege la plataforma, pero el centro médico debe limitar los accesos solo a personal autorizado, usar MFA, y garantizar que los datos sensibles no se compartan indebidamente.

En función del tipo de servicio cloud utilizado (IaaS, PaaS o SaaS), las responsabilidades sobre la seguridad, configuración y mantenimiento cambian. La siguiente tabla muestra de forma clara **qué elementos gestiona el proveedor y cuáles deben ser gestionados por el cliente**, ayudando a entender mejor el alcance y los límites de cada modelo.

Esta distinción es clave para evitar errores comunes y proteger adecuadamente un entorno en la nube.



Tabla comparativa: ¿Quién se encarga de qué?

Elemento	Responsable en IaaS	Responsable en PaaS	Responsable en SaaS
Infraestructura física	Proveedor	Proveedor	Proveedor
Sistema operativo	Cliente	Proveedor	Proveedor
Aplicaciones y datos	Cliente	Cliente	Cliente
Configuración de red / firewall	Cliente	Cliente	Proveedor (en parte)
Control de usuarios y accesos	Cliente	Cliente	Cliente
Parches de seguridad	Cliente	Proveedor	Proveedor
Gestión de identidades (IAM)	Cliente	Cliente	Cliente



Debes conocer

El mayor número de brechas de seguridad en la nube **no se produce por errores del proveedor**, sino por **configuraciones incorrectas del cliente**. Por ejemplo:

- ✓ Buckets S3 mal configurados y públicos
- ✓ Uso de claves de acceso sin rotación
- ✓ Ausencia de autenticación multifactor
- ✓ Permisos excesivos para usuarios no técnicos

Por eso, aunque la nube proporciona herramientas muy potentes de seguridad, **su correcta aplicación sigue siendo responsabilidad de quien la usa**.



Autoevaluación

Conteste a las siguientes preguntas de verdadero o falso:

El proveedor cloud es siempre responsable de la seguridad de los datos almacenados por el cliente.

☐ Verdadero ☐ Falso

Falso

En el modelo de responsabilidad compartida, el proveedor protege la infraestructura subyacente, pero **el cliente es responsable de la configuración de seguridad de sus datos**, incluyendo cifrado, permisos y acceso.

El cliente es responsable de aplicar políticas de control de acceso en sus recursos cloud.

☐ Verdadero ☐ Falso

Verdadero

La **gestión de usuarios, roles y permisos (IAM)** es una responsabilidad del cliente, incluso en entornos SaaS. Configurar correctamente los accesos es clave para evitar brechas de seguridad.

El modelo de responsabilidad compartida es igual en todos los modelos cloud: IaaS, PaaS y SaaS.

☐ Verdadero ☐ Falso

Falso

Aunque el principio se mantiene, **la distribución de responsabilidades varía**: en IaaS el cliente gestiona más aspectos (como el sistema operativo), mientras que en SaaS el proveedor se encarga de casi todo, excepto la gestión de usuarios y configuración.

1.2 Control de la autenticación, autorización y federación.

El control de acceso en la nube no solo consiste en “entrar” o “no entrar”. Requiere una gestión precisa de **quién accede, cómo lo hace, a qué recursos y bajo qué condiciones**. Autenticación, autorización y federación son los pilares que permiten garantizar un acceso seguro, trazable y escalable en entornos distribuidos.

Los mecanismos que permiten controlar quién accede a qué en un entorno cloud, y cómo se integran con identidades externas

Los entornos cloud gestionan decenas o cientos de usuarios, desde administradores hasta aplicaciones automatizadas. Para garantizar la seguridad y trazabilidad, deben implementarse mecanismos robustos de **autenticación, autorización** y, en entornos corporativos, **federación de identidades**.

Estos tres conceptos están interrelacionados:

Autenticación (Authentication)

Es el proceso de **verificar la identidad de un usuario o sistema**. No es suficiente con saber quién quiere acceder: hay que comprobar que realmente es quien dice ser.

Métodos habituales:

- ✔ Usuario + contraseña
- ✔ Autenticación multifactor (MFA)
- ✔ Certificados digitales
- ✔ Claves API para servicios

✔ **Ejemplo:** Un usuario accede a AWS con su contraseña + código de autenticación desde Google Authenticator (MFA).

Autorización (Authorization)

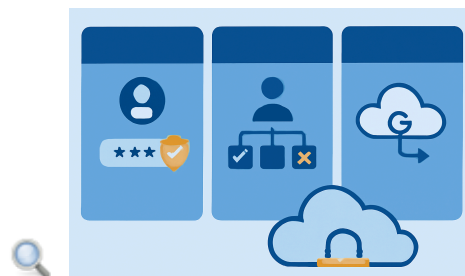
Una vez autenticado, el sistema define **a qué recursos puede acceder ese usuario** y qué puede hacer (leer, modificar, eliminar, etc.).

Esto se gestiona mediante **roles, políticas y permisos**.

Prácticas recomendadas:

- ✔ Principio de mínimo privilegio
- ✔ Separación de entornos (producción, desarrollo)
- ✔ Uso de grupos y roles en lugar de permisos directos

✓ **Ejemplo:** Un técnico de soporte puede consultar logs de CloudWatch, pero no puede modificar instancias EC2.



Elaboración propia. Modelos (CC BY-NC-SA)

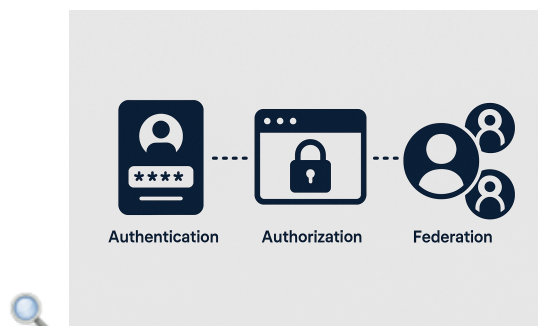
Federación de identidades (Identity Federation)

Permite que los usuarios **se autenticquen en la nube usando sus credenciales corporativas** o de terceros, sin necesidad de crear nuevas cuentas.

¿Qué ventajas tiene?

- ✓ Menor gestión de contraseñas
- ✓ Acceso centralizado y más seguro
- ✓ Integración con Active Directory, Google Workspace, Azure AD, etc.

✓ **Ejemplo:** Un empleado accede a la consola de AWS usando su cuenta de Microsoft 365 a través de SSO (inicio de sesión único).



Elaboración propia. AAF (CC BY-NC-SA)

Para gestionar correctamente la seguridad en un entorno cloud, es esencial entender la diferencia entre autenticación, autorización y federación. Cada uno de estos conceptos cumple una función específica en el control de acceso a los recursos.

La siguiente tabla resume de forma clara qué gestiona cada uno y lo acompaña de un ejemplo práctico para ilustrar su aplicación real.

Conceptos clave

Concepto	¿Qué gestiona?	Ejemplo práctico
Autenticación	Verifica identidad	Usuario + contraseña + código MFA
Autorización	Define lo que puede hacer el usuario	Puede ver logs, pero no lanzar instancias

Concepto	¿Qué gestiona?	Ejemplo práctico
Federación	Permite usar credenciales externas para acceder	Entrar en AWS con cuenta de Google sin crear usuario adicional



Caso práctico

Una empresa ha migrado sus servicios a la nube y ha comenzado a gestionar usuarios directamente desde la consola del proveedor cloud. A medida que el número de empleados crece, se vuelve difícil controlar los accesos y las cuentas duplicadas. Además, algunos empleados tienen permisos excesivos, lo que genera riesgo de modificación de servicios críticos. El equipo de seguridad busca una solución para centralizar el control de identidad y acceso sin perder trazabilidad.

👉 **¿Qué medidas debería aplicar la empresa para solucionar estos problemas?**



Ejercicio Resuelto

Responde las siguientes preguntas:

¿Qué objetivo cumple la autenticación en un sistema cloud?

Mostrar retroalimentación

✅ **Respuesta:** Verificar que el usuario es quien dice ser, mediante credenciales válidas (contraseña, MFA, certificados, etc.).

¿Qué principio debe aplicarse al asignar permisos en la nube?

Mostrar retroalimentación

✅ **Respuesta:** El principio de mínimo privilegio, otorgando solo los accesos estrictamente necesarios a cada usuario o rol.

¿Qué ventaja ofrece la federación de identidades?

Mostrar retroalimentación

✅ **Respuesta:** Permite a los usuarios acceder a recursos cloud utilizando sus credenciales corporativas existentes, sin necesidad de crear nuevas cuentas.

1.3 Seguridad en las cuentas.

Una mala gestión de cuentas y credenciales en la nube puede abrir la puerta a accesos no autorizados, filtraciones de datos o interrupciones graves del servicio. Por eso, proteger las cuentas de usuarios y servicios es una **prioridad crítica** en cualquier estrategia de seguridad cloud.

¿Qué prácticas aseguran una correcta gestión de cuentas y credenciales en la nube?

En los entornos cloud, cada usuario o sistema accede mediante **identidades digitales**. Estas pueden ser personas (administradores, desarrolladores, operadores), aplicaciones, scripts o servicios externos. Si no se gestionan de forma segura, representan uno de los vectores de ataque más comunes.

Tipos de cuentas en la nube

- ✔ **Cuenta raíz (root)** o superadministrador: acceso completo e ilimitado.
- ✔  **Cuentas de usuario IAM:** asociadas a roles y permisos específicos.
- ✔ **Identidades de servicios:** utilizadas por funciones, contenedores o APIs.

Buenas prácticas para la seguridad en cuentas

1. **Desactivar el uso habitual de la cuenta root**
 - ✔ Solo usarla para tareas iniciales o críticas.
 - ✔ Protegerla con autenticación multifactor (MFA).
2. **Usar cuentas individuales y no compartidas**
 - ✔ Cada usuario debe tener su cuenta IAM personal.
 - ✔ Se evita compartir contraseñas o claves.
3. **Aplicar el principio de mínimo privilegio**
 - ✔ Asignar permisos mínimos necesarios.
 - ✔ Separar acceso a producción y desarrollo.
4. **Activar autenticación multifactor (MFA)**
 - ✔ Añadir una segunda capa de seguridad a todas las cuentas administrativas.
5. **Rotar claves y credenciales periódicamente**
 - ✔ Evitar claves que no expiran.
 - ✔ Usar servicios como  AWS Secrets Manager o Azure Key Vault.
6. **Auditar accesos y cambios con regularidad**
 - ✔ Revisar logs (CloudTrail, Audit Logs) para detectar comportamientos anómalos.



Elaboración propia. Control ([CC BY-NC-SA](#))

Ejemplo aplicado

Una empresa de logística usaba una cuenta root para tareas diarias de **configuración**. Tras detectar un uso sospechoso desde una IP desconocida, migraron a un sistema de control por **roles con MFA** y auditaron accesos. Gracias a los logs, descubrieron que un empleado aún tenía credenciales activas. Esta revisión evitó una filtración de **datos** y mejoró toda la **gestión de identidades**.

La gestión segura de cuentas es un pilar esencial en cualquier entorno en la nube. La siguiente tabla resume las **acciones más importantes que se deben aplicar** para proteger identidades digitales, junto con el **riesgo concreto que ayuda a mitigar cada una**.

Estas medidas no solo refuerzan la seguridad técnica, sino que también permiten cumplir con normativas y mantener el control sobre el acceso a recursos críticos.

Acciones críticas y su impacto en la seguridad de cuentas

Medida aplicada	Riesgo que previene
MFA en cuentas privilegiadas	Robo de contraseñas o accesos desde IP no autorizadas
No uso de cuenta root en operaciones diarias	Acceso total sin trazabilidad o control
Rotación de claves de acceso	Uso prolongado de credenciales expuestas
Cuentas IAM individuales	Uso compartido sin control ni logs
Auditoría de accesos y eventos	Actividad sospechosa sin visibilidad



Debes conocer



El 90% de las brechas en la nube están relacionadas con errores de configuración o malas prácticas de gestión de accesos.

Limitar el uso de la cuenta root, proteger credenciales y monitorear accesos son medidas simples pero críticas que marcan la diferencia entre un entorno seguro... y una catástrofe.



Autoevaluación

¿Cuál es la mejor práctica respecto al uso de la cuenta root en un entorno cloud como AWS?

- ☐ Usarla solo cuando falle una cuenta IAM
- ☐ Desactivarla para el uso diario y protegerla con MFA
- ☐ Compartirla entre el equipo para tareas administrativas
- ☐ Eliminarla tras configurar otras cuentas

Incorrecto. Aunque se puede usar en emergencias, lo correcto es restringir su uso al máximo.

Correcto. La cuenta root debe usarse solo para tareas puntuales, estar protegida con MFA y no ser usada diariamente.

Incorrecto. Compartirla debilita la trazabilidad y la seguridad.

Incorrecto. No se puede eliminar la cuenta root, pero sí limitar su uso.

Solución

1. Incorrecto
2. Opción correcta
3. Incorrecto
4. Incorrecto

¿Cuál de las siguientes acciones ayuda a evitar el uso prolongado de credenciales comprometidas?

- ☐ Usar claves permanentes para automatización
- ☐ Aplicar roles sin fechas de expiración
- ☐ Configurar rotación automática de claves de acceso
- ☐ Confiar en que las credenciales nunca se filtran

Incorrecto. Las claves permanentes son peligrosas si no se rotan.

Incorrecto. Las políticas sin expiración aumentan el riesgo.

Correcto. La rotación periódica de credenciales evita que se usen claves expuestas por largo tiempo.

Incorrecto. Confiar ciegamente en la seguridad sin medidas es un error común.

Solución

1. Incorrecto
2. Incorrecto
3. Opción correcta
4. Incorrecto

¿Qué medida permite identificar accesos sospechosos o no autorizados en un entorno cloud?

- ☐ Usar una cuenta compartida con permisos completos
- ☐ Confiar solo en contraseñas fuertes
- ☐ Desactivar logs para mejorar el rendimiento
- ☐ Habilitar auditoría de accesos y revisar los registros

Incorrecto. Una cuenta compartida impide la trazabilidad.

Incorrecto. Aunque útil, las contraseñas no permiten detectar incidentes.

Incorrecto. Desactivar logs impide monitoreo y análisis forense.

Correcto. La auditoría permite rastrear qué usuario accedió a qué y cuándo.

Solución

1. Incorrecto
2. Incorrecto
3. Incorrecto
4. Opción correcta

1.4 Seguridad en los datos.

En la nube, los datos son el activo más valioso... y también el más vulnerable. Garantizar su protección requiere aplicar técnicas como **el cifrado, la gestión de claves, la replicación segura y los backups automatizados**, todo ello sin comprometer el acceso legítimo a la información.

¿Cómo se protegen los datos almacenados y transmitidos en un entorno cloud moderno?

Los datos en la nube se encuentran **en reposo (almacenados)**, **en tránsito (cuando viajan por la red)** y a veces **en uso (mientras son procesados)**. En cada fase, pueden estar expuestos a riesgos si no se aplican mecanismos de protección adecuados.

Afortunadamente, los principales proveedores cloud ofrecen herramientas avanzadas para **🔒 cifrado, control de acceso, auditoría, backup y recuperación**.

🔒 Protección avanzada de datos en entornos cloud

La protección de los datos en la nube no solo implica cifrarlos, sino también asegurarse de que estén **siempre disponibles, íntegros y accesibles solo para quienes deben acceder**. Esta protección se aplica en distintos niveles: cuando los datos están **almacenados (en reposo)**, **en movimiento (en tránsito)** o cuando se procesan. Además, se deben implementar políticas claras de **backup, recuperación, replicación y 🔑 gestión de claves**.

🔒 Cifrado en reposo (at rest)

El cifrado en reposo protege los datos almacenados frente a accesos físicos o ciberataques que logren llegar al disco o almacenamiento. Incluso si alguien obtiene acceso físico al hardware, **los datos serán ilegibles sin la clave de descifrado**.

Los proveedores cloud ofrecen cifrado en reposo de forma automática en la mayoría de sus servicios, aunque se puede elegir quién controla las claves:

- ✔ **Claves gestionadas por el proveedor:** es el modo por defecto, cómodo pero con menor control.
- ✔ **CMEK (Customer Managed Encryption Keys):** el cliente gestiona las claves, con posibilidad de revocar o rotar.
- ✔ **BYOK (Bring Your Own Key):** el cliente importa sus propias claves, usadas sin que el proveedor pueda verlas.

✔ **Ejemplo:** Una base de datos RDS cifrada con claves personalizadas desde AWS KMS, protegida por rotación automática y control de acceso.



Cifrado en tránsito (in transit)

El cifrado en tránsito protege los datos **mientras viajan entre sistemas, usuarios y servicios**, como entre el navegador y un servidor web, o entre microservicios internos. Sin cifrado, cualquier atacante con acceso a la red podría interceptar los datos.

- ✔ Se usa  **TLS (HTTPS)** como protocolo estándar.
- ✔ También se pueden utilizar **VPNs**, túneles cifrados o conexiones privadas dedicadas.

✔ **Ejemplo:** Un sistema IoT que transmite lecturas en tiempo real a través de HTTPS desde sensores distribuidos a una plataforma de análisis.



Gestión de claves (KMS)

El **Key Management System** permite crear, almacenar, rotar y revocar claves de cifrado. Está integrado con los servicios de almacenamiento y bases de datos, y se puede usar para aplicar cifrado de alto nivel y cumplir normativas como ISO 27001 o RGPD.

- ✔ Permite auditar quién accedió a una clave y cuándo.
- ✔ Admite políticas de acceso, rotación y caducidad.

✔ **Ejemplo:** Google Cloud KMS cifra archivos de Cloud Storage con una clave diferente por proyecto y registra cada uso de la clave.



Backups, replicación y recuperación

La seguridad también implica **disponibilidad y resistencia**. No basta con tener los datos protegidos: hay que poder **recuperarlos en caso de pérdida o ataque**.

Las estrategias de respaldo en la nube incluyen:

- ✔ **Copias de seguridad automáticas** en múltiples versiones.
- ✔ **Replicación geográfica** entre zonas o regiones.
- ✔  **Snapshots** de discos o máquinas completas.
- ✔ **Pruebas de recuperación periódicas**, no solo confiar en que el backup funciona.

✔ **Ejemplo:** Una empresa que almacena historiales médicos configura backups diarios en Amazon RDS y replica los datos en otra región para recuperación ante desastres.



Elaboración propia. Seguridad (CC BY-NC-SA)

Técnicas clave para proteger los datos en la nube

En la nube, los datos están expuestos a múltiples riesgos si no se protegen adecuadamente en cada fase de su ciclo de vida. Desde el almacenamiento hasta la transmisión, su seguridad depende de aplicar un conjunto de técnicas bien integradas.

A continuación se presentan las **principales medidas de protección** que permiten garantizar la confidencialidad, integridad y disponibilidad de los datos en entornos cloud, con ejemplos que ilustran su aplicación práctica.

Cifrado en reposo

El cifrado en reposo protege los datos almacenados en discos, bases de datos o archivos. Aunque alguien acceda físicamente al recurso, no podrá leer el contenido sin la clave adecuada.

✓ **Ejemplo:** Un bucket de Amazon S3 cifrado con una clave propia ( CMEK).

Cifrado en tránsito

Protege los datos mientras se mueven entre sistemas (por ejemplo, entre un navegador y una  API, o entre dos servicios internos).

✓ **Ejemplo:** Uso de HTTPS para acceder a una plataforma web desde el navegador del cliente.

Gestión de claves (KMS)

Permite crear, rotar y controlar el acceso a las claves de cifrado. Su trazabilidad permite cumplir con normas como ISO 27001 o RGPD.

✓ **Ejemplo:** En Google Cloud, cada archivo en Cloud Storage se cifra con una clave administrada desde Cloud KMS.

Backups automáticos

Las copias de seguridad garantizan que los datos puedan recuperarse ante fallos, errores humanos o ciberataques.

✅ **Ejemplo:** Una base de datos de Azure SQL se respalda automáticamente cada 24 h y guarda los backups durante 7 días.

Replicación geográfica

La replicación entre regiones o zonas permite mantener el servicio disponible incluso si una parte del sistema falla.

✅ **Ejemplo:** AWS RDS replica su base de datos principal en otra zona de disponibilidad para tolerancia a fallos.



Autoevaluación

Response a las siguientes preguntas de verdadero o falso:

El cifrado en tránsito protege los datos almacenados en discos o bases de datos.

☐ Verdadero ☐ Falso

Falso

El cifrado en tránsito protege los datos **mientras se transfieren** entre sistemas o usuarios. Los datos almacenados se protegen con **cifrado en reposo**.

El uso de claves gestionadas por el cliente (CMEK) permite tener mayor control sobre el cifrado de los datos.

☐ Verdadero ☐ Falso

Verdadero

Con CMEK, el cliente puede crear, rotar o revocar las claves de cifrado, lo que le otorga **más control y trazabilidad**, especialmente útil en entornos que deben cumplir normativas como RGPD.

Realizar backups automáticos y probar su restauración es parte fundamental de la seguridad de los datos.

☐ Verdadero ☐ Falso

Verdadero

La seguridad no solo implica proteger contra accesos indebidos, sino también garantizar que los datos puedan **recuperarse en caso de pérdida, fallo o ataque**. Sin pruebas de restauración, un backup puede ser inútil.

1.5 Seguridad en el cumplimiento normativo.

No basta con proteger técnicamente los sistemas: toda solución cloud debe ajustarse a **leyes, normativas y estándares de seguridad**. Cumplir con marcos legales como **el RGPD, ISO 27001 o HIPAA** garantiza no solo la legalidad, sino también la confianza y la transparencia hacia clientes y autoridades.

El cumplimiento con las normativas en la nube y cómo se garantiza desde el diseño

Cuando una organización migra servicios o datos a la nube, no solo está delegando infraestructura: también debe asegurar que el entorno cumple con las **exigencias legales y sectoriales** del país o mercado en que opera.

Esto se conoce como “ **compliance**” (cumplimiento) y engloba requisitos como:

- ✓ Protección de datos personales y sensibles
- ✓ Ubicación y residencia de los datos
- ✓ Retención, trazabilidad y borrado seguro
- ✓ Control de acceso y políticas de privacidad
- ✓ Auditorías y evidencias legales



Elaboración propia. Normativa [\(CC BY-NC-SA\)](#)

El uso de servicios en la nube debe alinearse con una serie de  **normativas legales y estándares internacionales** que regulan la gestión segura de los datos. Estas normas no solo garantizan la **protección de la información**, sino que también demuestran que una organización actúa con **responsabilidad y transparencia**.

A continuación se presentan las normativas más relevantes según el sector, el tipo de dato y la región, junto con sus objetivos principales.

Principales normativas y estándares

Normativa / Estándar	Ámbito de aplicación	Objetivo
RGPD (UE)	Protección de datos en Europa	Privacidad, consentimiento, localización de datos
ISO/IEC 27001	Internacional	Gestión de la seguridad de la información
HIPAA	EE. UU. / sector salud	Protección de datos sanitarios (PHI)
PCI-DSS	Global / pagos electrónicos	Seguridad de datos de tarjetas de pago
SOC 2 / SOC 3	EE. UU. / proveedores cloud	Controles sobre seguridad, disponibilidad, confidencialidad

¿Cómo se garantiza el cumplimiento en la nube?



Localización de los datos

La ubicación física de los datos en la nube es un aspecto clave del cumplimiento normativo. Algunas regulaciones —como el **RGPD europeo**— exigen que los datos personales se almacenen y procesen dentro de determinados territorios o bajo garantías legales específicas.

Una configuración incorrecta de la  **región de despliegue** puede suponer una infracción grave, incluso aunque el proveedor cloud cumpla con todas las certificaciones.

Ejemplo: Si una empresa española gestiona datos de clientes europeos, debe asegurarse de que los recursos se desplieguen en regiones como **europe-west1** (Madrid) o **europe-north1** (Finlandia) dentro del Espacio Económico Europeo.



Auditoría y trazabilidad

El cumplimiento normativo requiere poder **demostrar quién accedió a los datos, cuándo lo hizo y qué cambios realizó**. Esto se consigue mediante la activación de **logs de auditoría**, que generan un historial detallado de actividad en el entorno cloud.

Estos registros permiten:

- ✓ Detectar accesos sospechosos o fuera del horario laboral.
- ✓ Preparar informes de cumplimiento para auditorías externas.
- ✓ Generar alertas automatizadas ante acciones sensibles.

Ejemplo: AWS CloudTrail, Google Cloud Audit Logs o Azure Activity Logs permiten registrar cada acción de los usuarios y servicios, cumpliendo con requisitos de trazabilidad de normas como **ISO 27001** o **SOC 2**.



Políticas de acceso y retención

Las normativas suelen establecer cuánto tiempo deben conservarse los datos, cuándo deben eliminarse y **quién tiene permitido acceder** a ellos. En la nube, esto se implementa mediante:

- ✓ **Roles y permisos** (IAM)
- ✓ **Políticas de retención automática**
- ✓ **Etiquetas o tags** para clasificar datos sensibles

Una política mal definida puede provocar la conservación indebida de datos personales o el acceso de personal no autorizado.

Ejemplo: Configurar una política en Amazon S3 para que los backups de logs se borren automáticamente tras 90 días, cumpliendo con las normativas de minimización y retención del RGPD.



Certificaciones del proveedor

Aunque el cliente es el responsable final del cumplimiento, utilizar servicios de un proveedor con **certificaciones reconocidas** facilita y acelera el proceso. Estas certificaciones acreditan que la infraestructura cumple con estándares internacionales de seguridad, privacidad y control.

Las más relevantes incluyen:

- ✔  **ISO 27001 / 27017 / 27018** (gestión de la seguridad de la información)
- ✔ **RGPD** (protección de datos en Europa)
- ✔ **SOC 2 / SOC 3** (auditorías de proveedores cloud)
- ✔ **HIPAA** (protección de datos médicos en EE.UU.)
- ✔ **PCI-DSS** (datos de tarjetas de pago)

Ejemplo: Google Cloud y Azure cuentan con múltiples certificaciones globales que permiten a las organizaciones operar en sectores regulados como la sanidad, banca o educación.



Debes conocer

El cumplimiento **no es solo responsabilidad del proveedor cloud**. Aunque muchos servicios están certificados, el cliente debe:

- ✔ Elegir correctamente las regiones
- ✔ Configurar los controles de acceso
- ✔ Aplicar retención y borrado de datos
- ✔ Registrar evidencias de cumplimiento
- ✔ Prepararse para auditorías o inspecciones

El cumplimiento normativo debe planificarse desde el diseño ("**compliance by design**") y mantenerse de forma continua.



Ejercicio Resuelto

Una empresa española que trabaja con datos de clientes europeos aloja sus servicios en una región de EE.UU. ¿Cumple con el RGPD?

[Mostrar retroalimentación](#)

✓ **Respuesta:** No, no cumple con el RGPD. Esta normativa exige que los datos de ciudadanos europeos se almacenen y procesen dentro del Espacio Económico Europeo (EEE) o en países con garantías de protección equivalentes. Alojar los datos en EE.UU. sin medidas adicionales (como cláusulas contractuales tipo o mecanismos de transferencia válidos) puede constituir una infracción grave.

¿Cuál de los siguientes elementos ayuda a demostrar el cumplimiento normativo ante una auditoría?

[Mostrar retroalimentación](#)

✓ **Respuesta:** La activación de logs de auditoría y trazabilidad de accesos. Estos registros, disponibles en servicios como AWS CloudTrail o Azure Monitor, permiten documentar qué usuario accedió a qué recurso, cuándo y con qué permisos. Esta información es fundamental para superar auditorías de seguridad y demostrar cumplimiento con normas como ISO 27001, SOC 2 o RGPD.

¿Por qué es importante configurar políticas de retención y borrado automático de datos en la nube?

[Mostrar retroalimentación](#)

✓ **Respuesta:** Porque permite cumplir con el principio de minimización y limitación temporal del RGPD, el cual establece que los datos personales no deben conservarse más tiempo del estrictamente necesario. Configurar reglas automáticas de retención y eliminación en servicios como Amazon S3 o Google Cloud Storage reduce riesgos legales y mejora la higiene del entorno de datos.

